GDPR

Governance, Compliance, Controls, and Implementation Template

Joao Luiz D'Andrea

Table of contents

1 Executive Summary **3**

2 Overview **4**
2.1 Purpose . . . 4
2.2 Objectives . . . 4
2.3 Scope . . . 4
2.3.1 In scope . . . 4
2.3.2 Out of scope . . . 4
2.4 Intended Audience . . . 5

3 Regulatory Foundation **5**
3.1 Background . . . 5
3.2 Core Principles . . . 5
3.3 Legal Bases for Processing . . . 5
3.3.1 Template table . . . 6
3.4 Data Subject Rights . . . 6

4 Governance Model **6**
4.1 Governance Objectives . . . 6
4.2 Governance Structure . . . 6
4.2.1 Example governance bodies . . . 7
4.3 Three Lines Model . . . 7
4.3.1 First line . . . 7
4.3.2 Second line . . . 7
4.3.3 Third line . . . 7

5 Roles and Responsibilities **8**
5.1 Key Roles . . . 8
5.2 RACI Matrix . . . 8

6 Policy Framework **9**
6.1 Core Policies . . . 9
6.2 Standards and Procedures . . . 10

7 Core Processes **10**
7.1 Records of Processing Activities (RoPA) . . . 10
7.1.1 Minimum content . . . 10
7.2 Privacy Impact Assessment / DPIA . . . 10
7.3 Data Subject Request Management . . . 11
7.4 Consent Management . . . 11
7.5 Data Retention and Deletion . . . 11
7.6 Personal Data Breach Management . . . 11
7.7 Third-Party and Processor Management . . . 12
7.8 International Data Transfers . . . 12

8 Control Framework **12**
8.1 Control Domains . . . 12
8.1.1 Example control domains . . . 12
8.2 Sample Control Catalogue . . . 13

9 Artefacts and Evidence **13**
9.1 Required Artefacts . . . 13
9.2 Evidence Model . . . 14

10 Architecture and Data Management Implications **14**
10.1 Privacy by Design and by Default . . . 14
10.2 Data Lifecycle View . . . 14
10.3 Data Flow Mapping . . . 15

11 Risk Management **15**
11.1 Privacy Risk Model . . . 15
11.2 Example Risk Categories . . . 15
11.3 Risk Register Template . . . 15

12 Metrics and Reporting **16**
12.1 Key Metrics . . . 16
12.2 Dashboard Structure . . . 16

13 Audit and Assurance **16**
13.1 Assurance Model . . . 16
13.2 Testing Themes . . . 17

14 Implementation Roadmap **17**
14.1 Maturity Phases . . . 17
14.1.1 Phase 1: Foundation . . . 17
14.1.2 Phase 2: Control Design . . . 17
14.1.3 Phase 3: Integration . . . 17
14.1.4 Phase 4: Optimisation . . . 18
14.2 Roadmap Table . . . 18

15 Cross-Framework Integration **18**
15.1 Relationship to Other Frameworks . . . 18
15.2 Example Mapping Themes . . . 18

16 Maturity Model **19**
16.1 Suggested Maturity Levels . . . 19
16.1.1 Level 1: Initial . . . 19
16.1.2 Level 2: Repeatable . . . 19
16.1.3 Level 3: Defined . . . 19
16.1.4 Level 4: Managed . . . 19
16.1.5 Level 5: Optimised . . . 19
16.2 Assessment Dimensions . . . 19

17 Practical Templates **20**
17.1 Suggested Appendices . . . 20

18 Customisation Notes **20**

19 References **20**

1 Executive Summary

The General Data Protection Regulation (GDPR) is a foundational privacy and data protection framework governing the processing of personal data in the European Union and the European Economic Area, with extra-territorial reach where organisations process the data of EU data subjects. This document provides a structured governance and implementation template to support compliance, assurance, and continuous improvement.

This template can be used to document the organisation's GDPR operating model, control environment, compliance roadmap, and integration with wider governance, cybersecurity, risk, and data management frameworks.

2 Overview

2.1 Purpose

This document provides a practical template for defining, implementing, operating, and assuring GDPR compliance across the enterprise.

2.2 Objectives

The main objectives of GDPR compliance are to:

- protect the rights and freedoms of natural persons
- ensure lawful, fair, and transparent processing of personal data
- establish accountability for personal data governance
- reduce legal, financial, operational, and reputational risks
- embed privacy by design and by default into business and technology processes

2.3 Scope

Describe the scope of GDPR applicability in the organisation.

2.3.1 In scope

- business units processing personal data
- customer, employee, supplier, and partner data
- systems, applications, databases, and data flows containing personal data
- internal and external processors
- cross-border data transfers
- digital services, websites, and platforms

2.3.2 Out of scope

Document justified exclusions, if any.

2.4 Intended Audience

- Board and executive leadership
- Data Protection Officer
- Legal and compliance teams
- Information security teams
- IT and architecture teams
- Data owners and process owners
- Internal audit and assurance teams
- PMO / transformation teams

3 Regulatory Foundation

3.1 Background

GDPR establishes rules for the processing of personal data and strengthens the rights of individuals. It is built around accountability, lawful processing, risk-based controls, and enforceable rights.

3.2 Core Principles

Document how the organisation addresses the GDPR principles:

- lawfulness, fairness, and transparency
- purpose limitation
- data minimisation
- accuracy
- storage limitation
- integrity and confidentiality
- accountability

3.3 Legal Bases for Processing

Describe the legal bases used by the organisation, where applicable:

- consent
- contract
- legal obligation
- vital interests
- public task
- legitimate interests

3.3.1 Template table

Processing Activity	Purpose	Data Category	Legal Basis	Special Category Data	Notes
Example	Example	Example	Example	Yes/No	Example

3.4 Data Subject Rights

Document how the organisation supports:

- right to be informed
- right of access
- right to rectification
- right to erasure
- right to restrict processing
- right to data portability
- right to object
- rights related to automated decision-making and profiling

4 Governance Model

4.1 Governance Objectives

Define the governance objectives for GDPR:

- ensure executive accountability
- assign clear ownership for personal data
- integrate privacy into change, operations, procurement, and architecture
- maintain evidence of compliance
- monitor and improve control effectiveness

4.2 Governance Structure

Describe the governance bodies and their responsibilities.

4.2.1 Example governance bodies

- Board / Risk Committee
- Executive Compliance Committee
- Data Protection Steering Committee
- Information Security Forum
- Data Governance Council
- Architecture Review Board
- Internal Audit

4.3 Three Lines Model

Describe responsibilities across the three lines.

4.3.1 First line

- business ownership of data processing
- operational controls
- process execution
- evidence production

4.3.2 Second line

- privacy oversight
- compliance monitoring
- policy definition
- risk framework
- advisory support

4.3.3 Third line

- internal audit
- independent assurance
- effectiveness review

5 Roles and Responsibilities

5.1 Key Roles

Document the main GDPR roles.

- Board
- CEO / Executive Management
- Data Protection Officer
- Chief Information Security Officer
- Chief Information Officer
- Chief Data Officer
- Legal Counsel
- HR Lead
- Procurement Lead
- Business Process Owner
- System Owner
- Data Owner
- Records Manager
- Internal Audit

5.2 RACI Matrix

Use the following model and adapt it.

Activity	Board	Exec	DPO	Legal	CISO	CIO	Business Owner	Data Owner	Audit
Approve privacy policy	A	R	C	C	C	C	I	I	I
Maintain records of processing	I	A	C	C	I	I	R	R	I
Conduct DPIA	I	A	C	C	C	C	R	R	I

Activity	Board	Exec	DPO	Legal	CISO	CIO	Business Owner	Data Owner	Audit
Manage data subject requests	I	A	C	C	I	I	R	R	I
Personal data breach response	I	A	C	C	R	R	C	C	I
Third-party due diligence	I	A	C	C	C	C	R	C	I
Compliance monitoring	I	A	R	C	C	C	C	C	I
Independent assurance	I	I	I	I	I	I	I	I	R/A

6 Policy Framework

6.1 Core Policies

List and describe the main GDPR-related policies.

- Data Protection Policy
- Privacy Policy
- Records Retention Policy
- Information Classification Policy
- Access Control Policy

- Incident Response Policy
- Third-Party Risk Management Policy
- Secure Development Policy
- Data Subject Rights Procedure
- Personal Data Breach Procedure

6.2 Standards and Procedures

Document the standards and operating procedures supporting compliance.

7 Core Processes

7.1 Records of Processing Activities (RoPA)

Describe how the organisation maintains a complete inventory of processing activities.

7.1.1 Minimum content

- controller / processor details
- purpose of processing
- categories of data subjects
- categories of personal data
- recipients
- international transfers
- retention periods
- security measures

7.2 Privacy Impact Assessment / DPIA

Describe the process for:

- identifying high-risk processing
- triggering a DPIA
- assessing necessity and proportionality
- identifying privacy risks
- defining controls and mitigations
- approving risk treatment
- consulting supervisory authorities where required

7.3 Data Subject Request Management

Document the lifecycle for requests:

- intake
- verification
- logging
- triage
- fulfilment
- exemptions review
- approval
- response
- evidence retention

7.4 Consent Management

Where consent is used, describe how the organisation manages:

- collection
- granularity
- proof of consent
- withdrawal
- preference changes
- renewal where applicable

7.5 Data Retention and Deletion

Describe how retention periods are defined and enforced.

7.6 Personal Data Breach Management

Document the breach workflow:

- detection
- triage
- containment
- assessment
- legal and privacy review
- notification decision
- supervisory authority notification
- data subject communication

- remediation
- lessons learned

7.7 Third-Party and Processor Management

Describe controls for:

- due diligence
- contract clauses
- data processing agreements
- monitoring
- international transfer controls
- assurance reviews

7.8 International Data Transfers

Document how transfers are governed, such as:

- adequacy decisions
- standard contractual clauses
- transfer risk assessments
- supplementary measures

8 Control Framework

8.1 Control Domains

Organise GDPR controls into domains.

8.1.1 Example control domains

- governance and accountability
- lawful basis management
- transparency and notices
- data subject rights
- data minimisation
- retention and disposal
- access control
- encryption and security
- breach management

- third-party governance
- transfer controls
- monitoring and assurance

8.2 Sample Control Catalogue

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
GDPR-01	RoPA maintained	Ensure processing visibility	DPO	Quarterly	RoPA register
GDPR-02	DPIA performed	Assess high-risk processing	Business Owner	As needed	Approved DPIA
GDPR-03	DSAR workflow monitored	Protect data subject rights	Privacy Manager	Monthly	DSAR log
GDPR-04	Breach notification process	Meet notification duties	CISO / DPO	As needed	Incident records
GDPR-05	Processor due diligence	Reduce third-party risk	Procurement	Annual / onboarding	Due diligence file

9 Artefacts and Evidence

9.1 Required Artefacts

Document the key GDPR artefacts.

- privacy policy
- employee privacy notice
- customer privacy notice
- records of processing activities
- lawful basis register
- consent records
- DPIA register
- data transfer register
- retention schedule
- processor register

- data processing agreements
- breach register
- data subject request register
- training records
- monitoring reports
- audit reports

9.2 Evidence Model

For each artefact define:

- owner
- purpose
- location
- frequency of update
- retention period
- assurance mechanism

10 Architecture and Data Management Implications

10.1 Privacy by Design and by Default

Describe how privacy requirements are embedded into:

- solution design
- data modelling
- application development
- procurement
- cloud adoption
- analytics and AI initiatives
- data sharing
- identity and access management

10.2 Data Lifecycle View

Document the lifecycle of personal data:

- collection
- storage
- use
- sharing

- archival
- deletion

10.3 Data Flow Mapping

Include or reference:

- system landscape diagrams
- data flow diagrams
- processor ecosystem maps
- cross-border transfer maps

11 Risk Management

11.1 Privacy Risk Model

Describe how privacy risks are identified, assessed, treated, and monitored.

11.2 Example Risk Categories

- unlawful processing
- excessive data collection
- inadequate transparency
- failure to fulfil data subject rights
- weak access controls
- excessive retention
- unauthorised disclosure
- processor non-compliance
- uncontrolled transfers
- poor evidence and accountability

11.3 Risk Register Template

Risk ID	Risk Description	Cause	Impact	Likelihood	Inherent Risk	Control Strength	Residual Risk	Owner
PR-01	Example	Example	Example	Medium	High	Medium	Medium	Example

12 Metrics and Reporting

12.1 Key Metrics

Examples of GDPR metrics:

- percentage of processing activities recorded in RoPA
- number of overdue DPIAs
- percentage of staff completing privacy training
- number of data subject requests received
- average fulfilment time for requests
- number of personal data breaches
- percentage of third parties with signed DPAs
- percentage of records with defined retention rules
- number of transfer assessments completed
- audit findings open vs closed

12.2 Dashboard Structure

Suggested dashboard views:

- executive dashboard
- compliance dashboard
- operational privacy dashboard
- incident and breach dashboard
- third-party privacy dashboard

13 Audit and Assurance

13.1 Assurance Model

Document the assurance approach across:

- management self-assessment
- second-line compliance reviews
- control testing
- internal audit
- external audit or certification support where relevant

13.2 Testing Themes

- governance and accountability
- evidence of lawful basis
- privacy notice quality
- DSAR effectiveness
- DPIA completeness
- breach notification timeliness
- processor management
- retention enforcement
- transfer governance

14 Implementation Roadmap

14.1 Maturity Phases

14.1.1 Phase 1: Foundation

- establish governance
- define policies
- identify roles
- create RoPA baseline
- launch awareness training

14.1.2 Phase 2: Control Design

- implement DPIA process
- implement DSAR workflow
- define retention schedules
- implement breach procedures
- formalise processor management

14.1.3 Phase 3: Integration

- embed privacy in projects and architecture
- integrate with risk and security processes
- automate evidence collection
- improve data discovery and mapping

14.1.4 Phase 4: Optimisation

- implement metrics and dashboards
- conduct deep assurance reviews
- strengthen automation
- improve continuous monitoring

14.2 Roadmap Table

Initiative	Description	Owner	Priority	Timeline	Dependency	Status
Example	Example	Example	High	Q1-Q2	Example	Planned

15 Cross-Framework Integration

15.1 Relationship to Other Frameworks

Describe how GDPR integrates with:

- ISO/IEC 27001
- NIS2
- DORA
- AI Act
- COBIT
- ITIL
- TOGAF
- enterprise risk management
- records management
- data governance

15.2 Example Mapping Themes

GDPR Theme	Related Framework	Integration Point
Accountability	COBIT	Governance and management objectives
Security of processing	ISO 27001	ISMS controls
Incident response	NIS2 / DORA	Cyber incident management
Privacy by design	TOGAF	Architecture governance
AI data governance	AI Act	Data and model compliance

16 Maturity Model

16.1 Suggested Maturity Levels

16.1.1 Level 1: Initial

Compliance is reactive and fragmented.

16.1.2 Level 2: Repeatable

Basic processes exist but are inconsistent.

16.1.3 Level 3: Defined

Policies, roles, and processes are documented and followed.

16.1.4 Level 4: Managed

Controls are measured, monitored, and regularly improved.

16.1.5 Level 5: Optimised

Privacy is embedded, automated, risk-driven, and fully integrated into enterprise governance.

16.2 Assessment Dimensions

- governance
- legal basis management
- transparency
- data subject rights
- breach management
- third-party governance
- retention
- data architecture
- assurance
- metrics

17 Practical Templates

17.1 Suggested Appendices

- Appendix A: RoPA template
- Appendix B: DPIA template
- Appendix C: Data subject request register
- Appendix D: Breach register
- Appendix E: Processor due diligence checklist
- Appendix F: Data transfer assessment template
- Appendix G: GDPR control catalogue
- Appendix H: GDPR RACI matrix

18 Customisation Notes

This template should be tailored to reflect:

- organisational structure
- jurisdictions and supervisory authorities
- business model
- data categories processed
- outsourcing profile
- cloud estate
- sector-specific obligations
- assurance expectations

19 References

Add authoritative references here, for example:

- GDPR legal text
- EDPB guidelines
- ICO guidance
- national supervisory authority guidance
- internal privacy policies
- enterprise risk framework
- security standards and control libraries